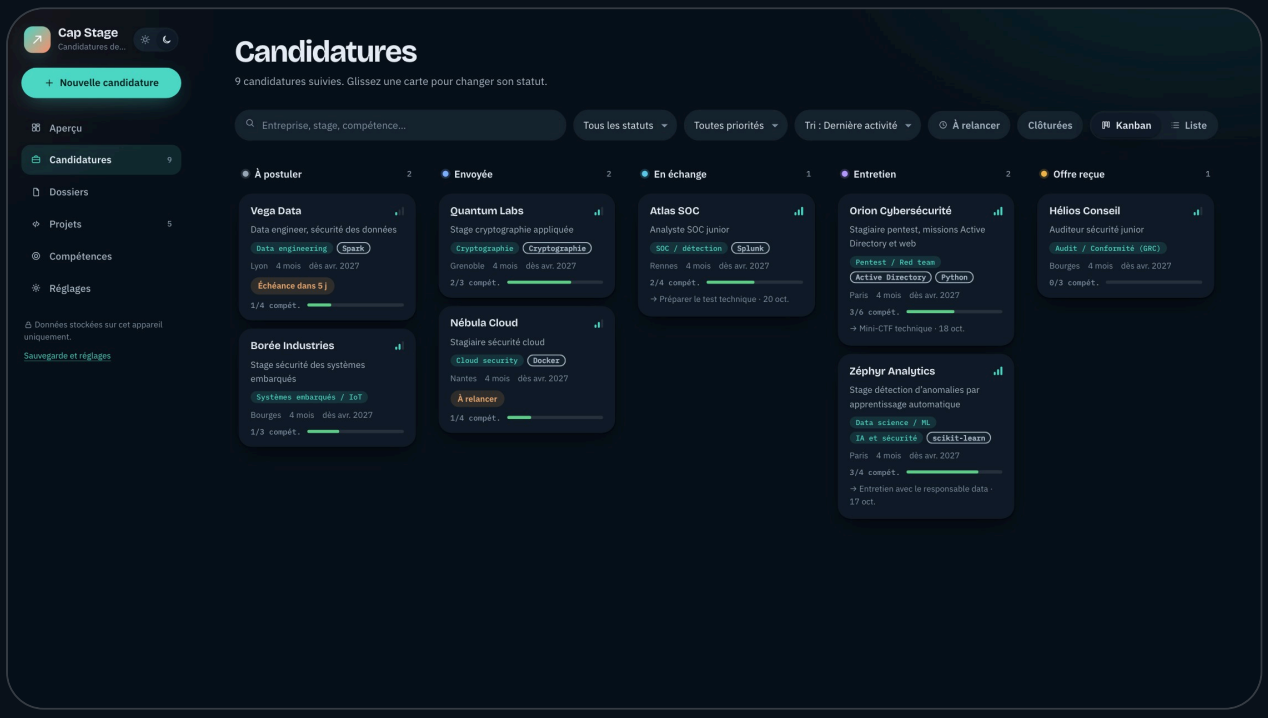
RAPPORT DE PROJET · OCTOBRE 2026

Cap Stage

Une plateforme libre et privée pour suivre ses candidatures de stage : entreprises, compétences demandées, documents envoyés, projets réalisés.



Mohamed Aziz Baoueb
INSA Centre Val de Loire · Sécurité et Technologies Informatiques (STI), 4e année

aziz3r.github.io/cap-stage
github.com/aziz3r/cap-stage

SOMMAIRE

01 Contexte et objectifs
02 Exigences
03 Fonctionnalités
04 Architecture
05 Sécurité et vie privée
06 Synchronisation et compatibilité
07 Qualité : tests et défauts corrigés
08 Déploiement
09 Limites et perspectives
10 Compétences mobilisées

Résumé

Cap Stage répond à un besoin précis : suivre de façon fluide plusieurs dizaines de candidatures de stage, avec pour chacune le stage proposé, les compétences réellement demandées, ce que l'entreprise cherche, les documents déjà envoyés et les projets mis en avant. L'outil est un site statique d'un seul fichier, sans serveur ni compte à créer, gratuit et partageable à des personnes non informaticiennes.

Les données restent chez l'utilisateur : enregistrées dans son navigateur, éventuellement chiffrées par mot de passe, et synchronisables vers un dossier de son ordinateur ou vers l'espace caché de son propre Google Drive. Le projet a servi de terrain d'application pour la sécurité applicative (politique de sécurité du contenu, validation des entrées, chiffrement côté client), la cryptographie appliquée (AES-GCM, PBKDF2), l'authentification OAuth 2.0 et la conception d'interface.

1 fichier
152 Ko de code source, aucune dépendance

9 vues
aperçu, kanban, fiche, dossiers, projets, compétences, réglages, connexion, verrouillage

2 thèmes
clair et sombre, mobile et ordinateur

0 serveur
les données ne transitent par aucun serveur de l'auteur

1. Contexte et objectifs

En 4e année du cycle ingénieur STI de l'INSA Centre Val de Loire, le stage est de quatre mois et débute en avril. La recherche s'étale sur l'automne : une trentaine d'offres à repérer, comparer, relancer, avec des pièces différentes selon les entreprises.

Le problème

Un tableur ou un carnet ne permettent pas de répondre vite à des questions simples : *qui ai-je relancé ? quelle version du CV a reçu telle entreprise ? quelles compétences reviennent le plus, et lesquelles ne figurent dans aucun de mes projets ? quel projet ai-je présenté à qui ?* Les outils généralistes (kanban, CRM) n'ont ni la notion de couverture de compétences ni celle de dossier envoyé.

Objectifs

- **Organiser** chaque candidature : domaine, stage proposé, compétences demandées avec les plus importantes, « ce qu'ils cherchent vraiment », contraintes (habilitation, nationalité), équipe, processus de recrutement, prochaine étape.
- **Tracer** ce qui a été fourni à chaque entreprise : documents, version, date.
- **Relier** les offres aux projets réalisés et mesurer la couverture des compétences.
- **Protéger** les données : elles décrivent une recherche d'emploi et contiennent des coordonnées de tiers.
- **Partager** l'outil à des amis qui ne sont pas informaticiens : aucune installation, aucun compte à créer, interface soignée.

Choix structurant. Plutôt qu'un service avec base de données et comptes, un site statique « local d'abord » : chaque personne détient ses données. Cela supprime le serveur à sécuriser et à héberger, mais impose de résoudre la synchronisation entre appareils (section 6).

2. Exigences

EXIGENCE	CRITÈRE DE RÉUSSITE
Suivi complet d'une candidature	Statut sur 8 états, historique daté, relances automatiques après 10 jours, contacts, notes, prochaine action.
Synthèse lisible	Chaque fiche s'ouvre sur un résumé reprenant domaine, compétences clés, besoin réel, stage en bref, documents et projets.
Couverture des compétences	Comparaison automatique offres / projets, compétences marquées « clés », lacunes visibles.
Données privées	Aucun envoi vers un tiers par défaut ; chiffrement optionnel ; effacement complet.

Sans compte, sans installation	Un lien suffit ; fonctionne sur ordinateur et téléphone.
Sauvegarde et portabilité	Export JSON et CSV, import, dossier de sauvegarde automatique, synchronisation Google Drive.
Accessibilité et confort	Thèmes clair et sombre, navigation au clavier, mouvements réduits si demandé, adaptation mobile.

3. Fonctionnalités

Aperçu : l'essentiel en un coup d'œil

La page d'accueil résume la recherche : compteur jusqu'au début du stage, chiffres clés (candidatures, envois, taux de réponse, entretiens, offres), liste des relances et échéances, pipeline par statut et compétences les plus demandées.

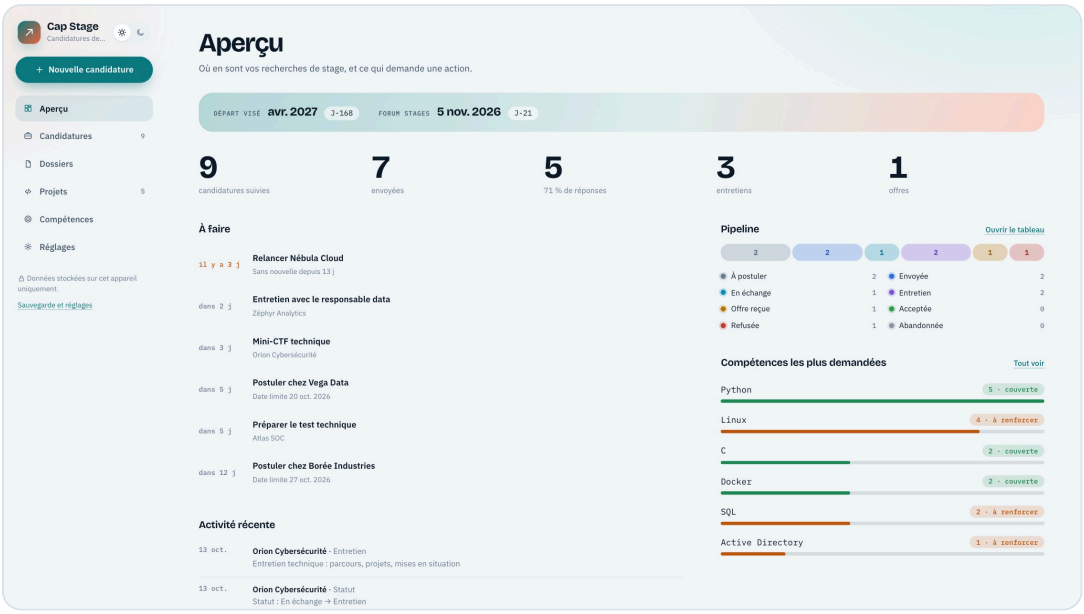


Figure 1. L'aperçu : chiffres clés, relances à faire, pipeline et compétences les plus demandées.

Candidatures : un kanban à glisser

Les candidatures sont réparties en colonnes (À postuler, Envoyée, En échange, Entretien, Offre reçue). Une carte se glisse d'une colonne à l'autre ; la liste offre les mêmes informations en tableau, avec filtres, recherche et tris. Un badge signale les relances à faire et les échéances proches.

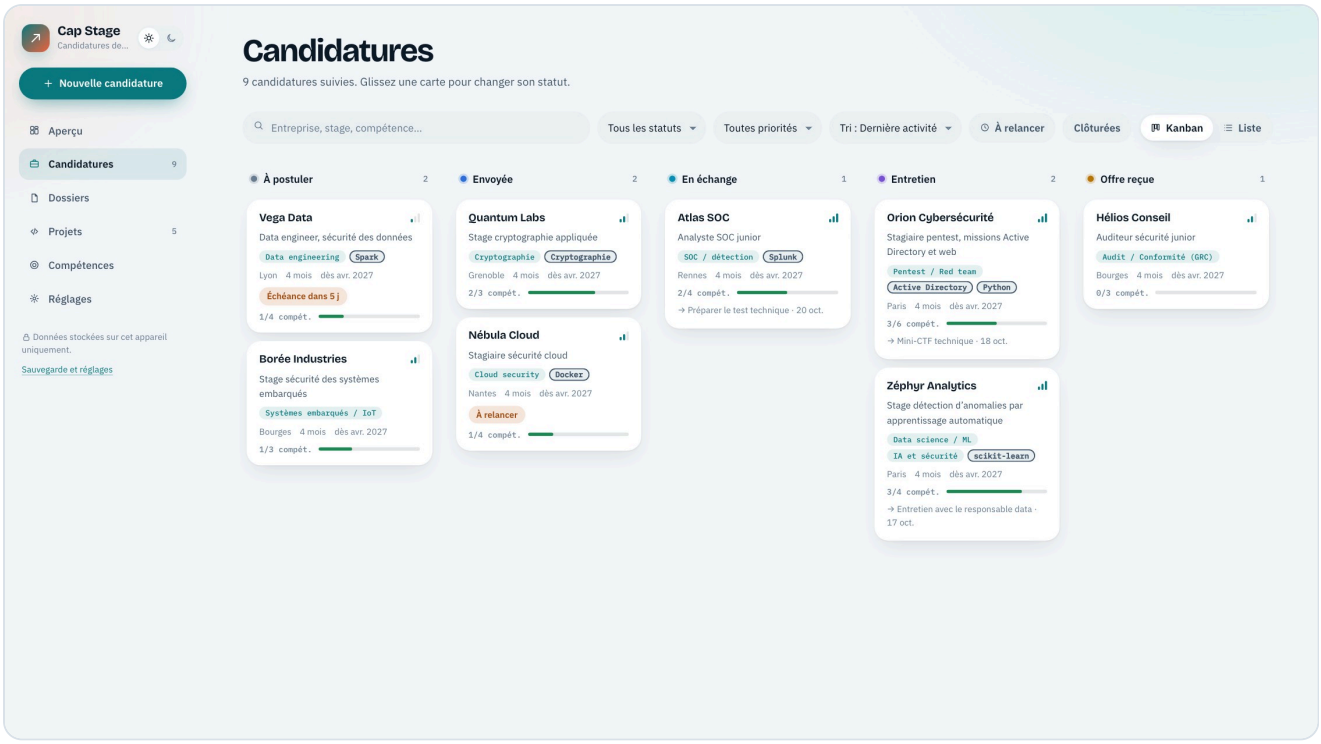


Figure 2. Le kanban en mode clair : domaine, compétences clés et couverture sur chaque carte.

La fiche : une synthèse avant le détail

Chaque candidature s'ouvre sur une synthèse qui se met à jour en direct pendant la saisie. Les compétences demandées sont colorées selon qu'elles sont démontrées par un projet (vert) ou non (orange), et une étoile marque celles sur lesquelles l'entreprise insiste.

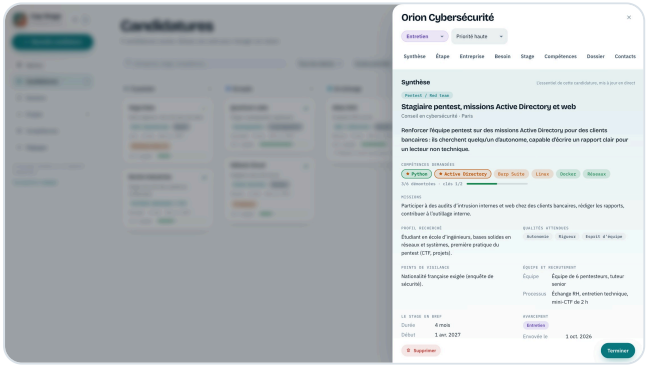


Figure 3a. Synthèse (clair).

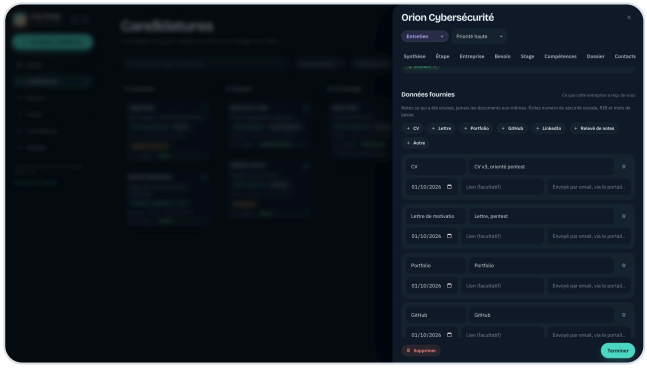


Figure 3b. Compétences clés, section d'édition (sombre).

Dossiers envoyés : qui a reçu quoi

Une matrice croise les entreprises et les types de documents (CV, lettre, portfolio, GitHub, LinkedIn, relevés). Elle répond à « quelle version est partie où ? » et regroupe les versions envoyées.

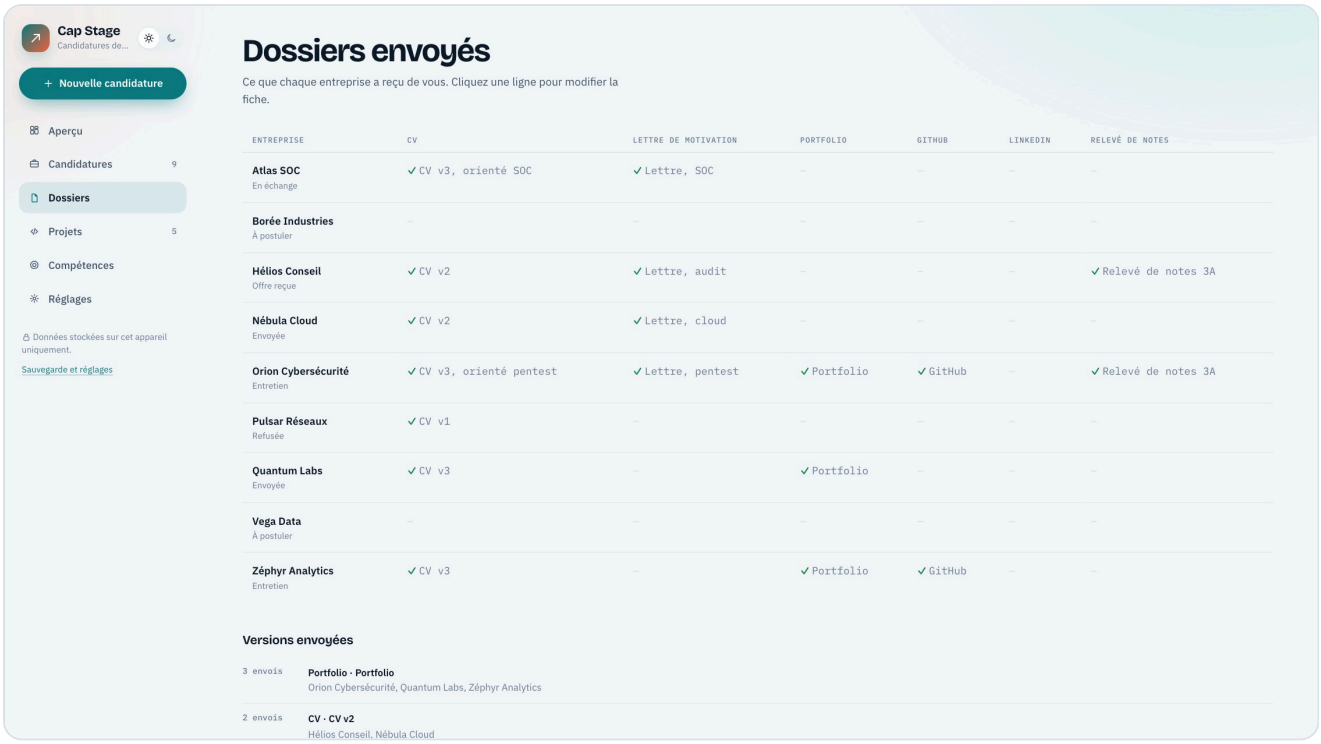


Figure 4. La matrice des documents fournis à chaque entreprise.

Projets et compétences

Chaque projet réalisé a sa fiche (contexte, rôle, technologies, résultats, liens, pitch de trente secondes). Les technologies et compétences des projets alimentent l'analyse de couverture : ce que demandent les offres, face à ce que démontre le portfolio.

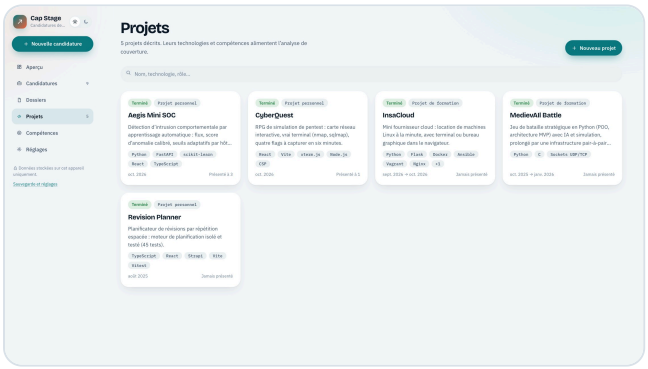


Figure 5a. Fiches projets.

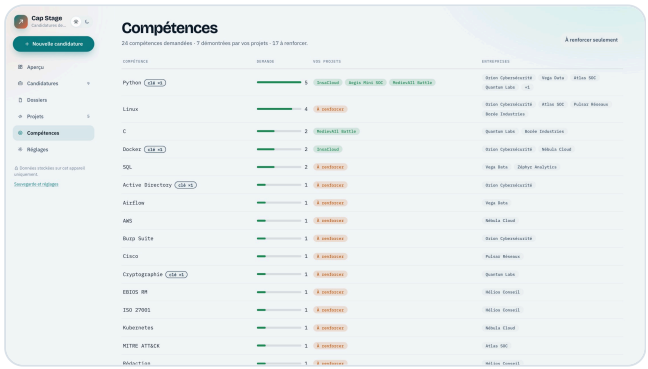


Figure 5b. Couverture des compétences.

Deux thèmes et une version mobile

L’interface est « ouverte » : peu de cadres, des filets fins, des cartes douces seulement pour ce qui se manipule. Le thème suit le réglage de l’appareil ou se choisit d’un bouton, et l’interface mobile remplace le menu par une barre de navigation flottante.

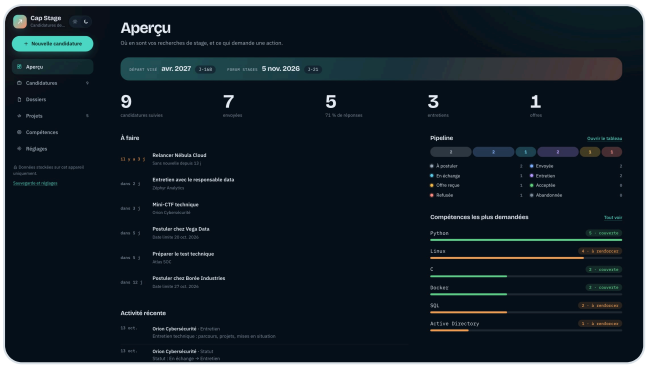


Figure 6a. Aperçu en mode sombre.



Figure 6b. Mobile, clair.

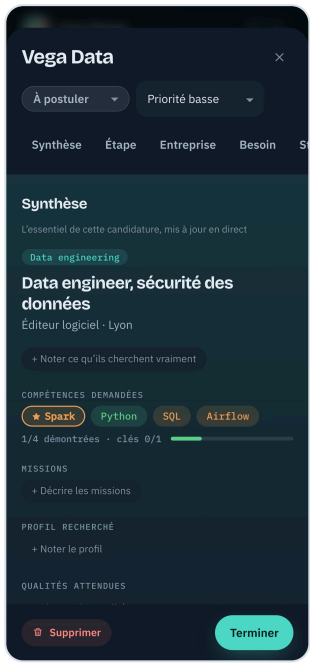


Figure 6c. Mobile, sombre.

4. Architecture

L’application est un unique fichier HTML (CSS et JavaScript sans dépendance ni outil de compilation), servi par GitHub Pages. Un script de construction génère la page et sa politique de sécurité à partir d’un fichier source.

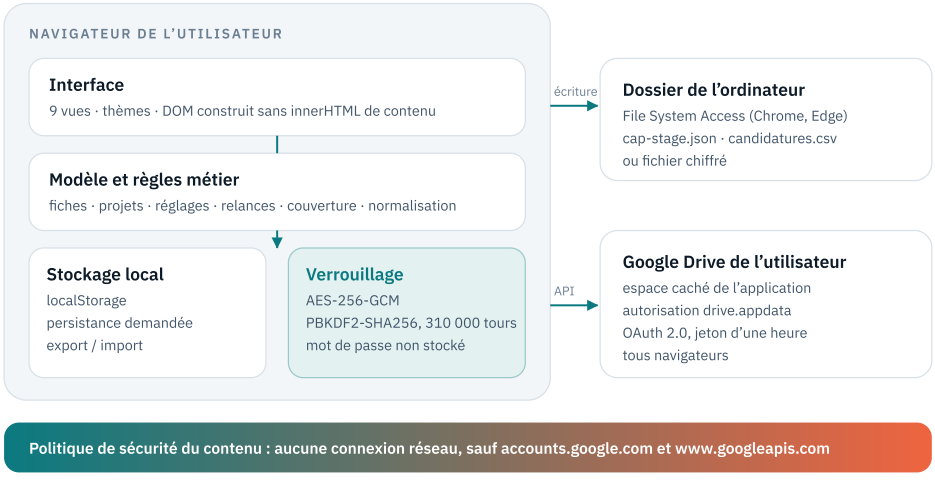


Figure 7. Architecture : couches de stockage et frontière de sécurité.

Modèle de données

COLLECTION	CONTENU
apps	Une candidature : entreprise, domaines, stage, durée, lieu, compétences et compétences clés, besoin réel, qualités attendues, contraintes, équipe, processus, documents fournis, contacts, historique, projets présentés, prochaine action, dates.
projects	Un projet : contexte, période, rôle, technologies, compétences démontrées, résultats, liens, apprentissages, pitch.
settings	Début de stage visé et événement à suivre.

Une couche d'abstraction expose deux implémentations du stockage (local, ou base documentaire pour une version hébergée comme page privée). Tous les documents lus passent par une fonction de normalisation qui force les types, borne les énumérations et remplace les valeurs inattendues, ce qui rend le rendu robuste face à des données mal formées.

5. Sécurité et vie privée

Une recherche de stage décrit des contacts, des échanges et des candidatures qui n'ont pas vocation à être publics. La conception part d'un principe simple : **ne pas détenir les données**, puis réduire ce qui peut en sortir.

MENACE	MESURE MISE EN ŒUVRE
Envoi de données vers un tiers	Politique de sécurité du contenu (`connect-src`) : sans synchronisation Google, aucune connexion n'est possible ; avec, seuls `accounts.google.com` et `www.googleapis.com` sont autorisés. Ni cookies, ni analyse, ni publicité.
Lecture des données sur l'appareil	Verrouillage optionnel : chiffrement AES-256-GCM, clé dérivée du mot de passe par PBKDF2-SHA256 (310 000 itérations, sel aléatoire, vecteur d'initialisation neuf à chaque écriture). Le mot de passe n'est jamais stocké.
Appareil partagé entre deux personnes	Les données sont rattachées à l'identifiant opaque du compte Google. Une autre personne qui se connecte ne voit rien ; l'appareil doit être effacé pour continuer. Bouton « Se déconnecter et effacer cet appareil ».
Fichier de sauvegarde piégé	Taille limitée à 8 Mo, 3 000 fiches maximum, identifiants en liste blanche, rejet des clés `__proto__` et `constructor` , normalisation de chaque champ.
Injection de code (XSS)	Le contenu saisi n'est jamais injecté comme HTML : l'interface est construite par l'API DOM (`textContent`). Les liens sont limités à `http(s)` , ouverts avec `noopener` et sans référent.

Saisie de données sensibles	Détecteur de numéro de sécurité sociale, IBAN, numéro de carte et mot de passe : un avertissement s'affiche à la saisie.
Portée OAuth excessive	Trois autorisations non sensibles seulement : `drive.appdata` (espace caché de l'application), `openid` et `profile` (prénom et identifiant, pour saluer et séparer les comptes).
Perte de données	Stockage persistant demandé au navigateur, export JSON et CSV, copie de la version précédente dans le dossier de sauvegarde, rappel d'export, écriture atomique des fichiers.

Limite assumée. Le site partage son origine (`aziz3r.github.io`) avec le portfolio de l'auteur : une faille dans une autre page de cette origine pourrait lire le stockage local. Le verrouillage par mot de passe répond à ce risque ; il est recommandé dès que de vraies données sont saisies.

6. Synchronisation et compatibilité navigateurs

Le premier prototype enregistrait les données dans une base associée à une page privée. Le passage à un site public partageable a posé une contradiction : une page publique ne peut pas stocker des données privées côté serveur sans comptes ni base de données.

Démarche

- **Local d'abord.** Chaque navigateur garde ses données ; aucune donnée n'est dans le dépôt public.
- **Dossier de sauvegarde automatique.** L'API File System Access permet d'écrire dans un dossier choisi par l'utilisateur (création automatique du dossier « Cap Stage », écriture à chaque modification, copie précédente, fichier chiffré si le verrouillage est actif, détection de conflit à la reconnexion). Elle n'existe que dans les navigateurs de la famille Chrome.
- **Constat de terrain.** Dans le navigateur intégré à l'application de l'auteur, le sélecteur de dossier rejette immédiatement l'appel : l'outil le détectait comme une annulation et restait muet. Il détecte désormais ce cas et l'explique, et un rappel d'export prend le relais.
- **Compatibilité universelle.** La solution retenue pour des utilisateurs non informaticiens est la connexion Google : un bouton, puis un fichier dans l'espace caché de l'application dans leur propre Drive (`drive.appdata`). Les navigateurs, les appareils et les systèmes sont indifférents. L'auteur ne voit jamais ces données.

Flux Google

L'application utilise le modèle de jeton de Google Identity Services : fenêtre de connexion, jeton d'accès d'une heure conservé en mémoire seulement, appels à l'API Drive v3 depuis le navigateur. La bibliothèque est préchargée au survol du bouton pour que la fenêtre s'ouvre dans le geste de l'utilisateur (les navigateurs bloquent sinon la fenêtre). À l'expiration du jeton, l'écriture se met en pause et un bandeau propose de se reconnecter ; les modifications sont réécrites dès la reconnexion.

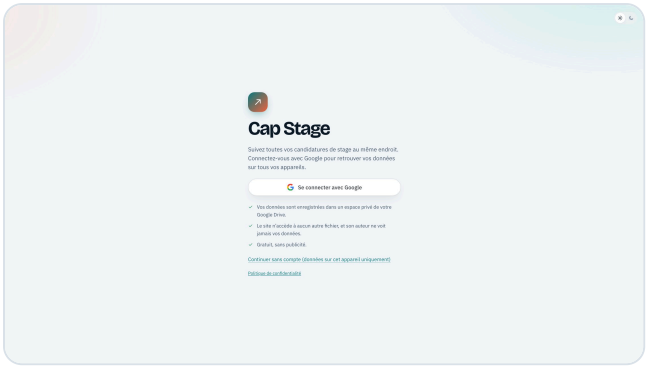


Figure 8a. Première page : connexion Google, ou « Continuer sans compte ».

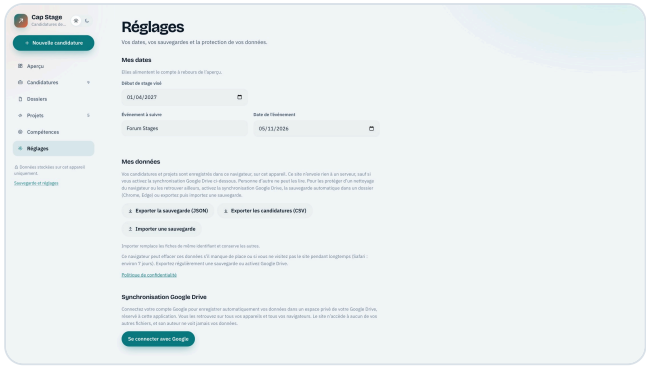


Figure 8b. Réglages : sauvegarde, dossier, verrouillage, effacement.

7. Qualité : tests et défauts corrigés

Sans cadre de test automatisé, la vérification s'est faite par des scénarios rejoués dans un navigateur piloté par script, sur des données fictives, puis par des simulateurs pour les services externes.

Scénarios rejoués

- Création, édition et suppression de fiches ; changement de statut par le menu et par glisser-déposer ; historique et relances.
- Import d'un fichier volontairement hostile (types incohérents, dates invalides, clés dangereuses), export JSON et CSV, effacement complet.
- Verrouillage : activation, fichier chiffré sans texte en clair, mauvais mot de passe, déverrouillage, désactivation.
- Dossier de sauvegarde, simulé en mémoire : création, écriture à chaque changement, bascule clair / chiffré, conflit, perte d'autorisation puis reconnexion.
- Google et API Drive, simulés : connexion, écriture automatique, expiration du jeton, fenêtre bloquée, deux comptes sur un appareil, deux appareils pour un compte.
- Affichage : thèmes clair et sombre, ordinateur et mobile, sans dépassement horizontal.

Défauts trouvés, puis corrigés

DÉFAUT	CORRECTION
Identifiants HTML dupliqués entre le filtre de statut et le tiroir	Identifiants renommés ; recherche systématique des doublons ajoutée aux vérifications.
Aperçu planté par une date invalide venue d'un fichier importé	Formateurs de date tolérants, dates validées à la lecture des réglages.

Fichier importé aux types incohérents	Normalisation complète de chaque champ, statuts et énumérations bornés.
Sélecteur de dossier silencieux dans le navigateur intégré	Détection de l'échec immédiat, message explicatif, rappel d'export.
Modifications faites pendant une pause d'autorisation non réécrites	Réécriture automatique à la reconnexion.
Salutation d'un autre utilisateur après une connexion annulée	Restauration de l'identité mémorisée de l'appareil.
Barre de navigation mobile piégée par un flou d'arrière-plan	Flou déplacé sur un pseudo-élément pour libérer le positionnement fixe.

Ce qui reste à valider en conditions réelles. La connexion avec un véritable compte Google et le sélecteur de dossier natif n'ont été exercés qu'avec des simulateurs ; un essai complet sur Chrome et Safari clôturera la recette.

8. Déploiement

- **Hébergement :** GitHub Pages, dépôt `aziz3r/cap-stage`. Le site se compose de `index.html`, `confidentialite.html` et du script `build/build.py` qui les génère depuis `build/source.html`.
- **Politique de sécurité :** insérée par le script de construction ; sans identifiant Google, elle interdit toute connexion réseau.
- **Google Cloud :** projet dédié, API Drive activée, écran de consentement externe publié en production avec trois autorisations non sensibles (aucune validation par Google requise), client OAuth de type application web limité à l'origine du site. L'identifiant client est public ; aucun secret n'est présent dans le dépôt.
- **Page de confidentialité :** décrit les données traitées, leur emplacement et les moyens de les supprimer.
- **Démonstration :** une vidéo de 1 min 50 (`docs/demo.mp4`) et les captures de ce document sont produites par un script pilotant Chrome (protocole DevTools) sur des données fictives, reproductible depuis le dépôt (`tools/capture.mjs`).

9. Limites et perspectives

Limites actuelles

- Pas de fusion fine entre appareils : en cas de différence, l'utilisateur choisit quel jeu de données conserver.
- Le jeton Google dure une heure : une reconnexion d'un clic est nécessaire à chaque session.
- Pas de glisser-déposer au doigt : sur mobile, le changement de statut passe par la liste.

- Pas de suite de tests automatisés ; les vérifications reposent sur des scénarios scriptés.

Perspectives

- Fusion par fiche (horodatage et marqueurs de suppression) pour des modifications simultanées.
- Application installable (PWA) et notifications locales de relance.
- Extraction assistée des compétences depuis le texte d'une offre.
- Tests de bout en bout automatisés dans une intégration continue, audit d'accessibilité complet.
- Chiffrement de bout en bout activé par défaut pour la synchronisation Google Drive.

10. Compétences mobilisées

DOMAINE	MISE EN PRATIQUE
Sécurité applicative	Politique de sécurité du contenu, prévention du XSS, validation et normalisation des entrées, modèle de menaces.
Cryptographie appliquée	AES-GCM, PBKDF2, gestion des sels et vecteurs d'initialisation, vérification du déchiffrement avant bascule.
Authentification et autorisation	OAuth 2.0 et OpenID Connect, principe du moindre privilège sur les autorisations, séparation des comptes.
Développement web	JavaScript moderne sans dépendance, API navigateur (stockage, WebCrypto, système de fichiers), gestion de l'asynchrone et des erreurs.
Conception d'interface	Systèmes de design à deux thèmes, responsive, mouvements maîtrisés, accessibilité clavier.
Qualité et déploiement	Scénarios de test scriptés, simulateurs de services externes, publication continue sur GitHub Pages.

Liens. Application : aziz3r.github.io/cap-stage · Code : github.com/aziz3r/cap-stage · Confidentialité : confidentialite.html